

PBL 2번

ISMS-P 인증기준의 이해

1. ISMS-P 인증기준

1.1 ISMS-P 인증기준 개요

ISMS-P(정보보호 및 개인정보보호 관리체계 인증)는 조직이 정보보호와 개인정보보호를 체계적으로 관리하고 있는지를 평가하기 위한 인증제도이다.

ISMS-P 인증기준은 단순히 보안 프로그램이나 장비를 사용하는지를 확인하는 것이 아니라, 조직에서 정보보호와 개인정보보호를 위한 관리체계를 만들고 실제로 운영하고 있는지를 평가한다. 또한 정보시스템과 개인정보를 보호하기 위한 구체적인 보호대책과 개인정보 처리 과정에서 필요한 보호조치도 포함한다.

ISMS-P 인증기준은 다음과 같이 3개 영역, 총 101개 인증기준으로 구성된다.

- 관리체계 수립 및 운영: 16개
- 보호대책 요구사항: 64개
- 개인정보 처리단계별 요구사항: 21개

따라서 총 101개의 인증기준으로 구성된다.

관리체계 수립 및 운영에서는 조직의 정보보호 및 개인정보보호 정책과 조직을 마련하고, 보호해야 할 자산과 위험을 확인한 후 적절한 보호대책을 수립한다. 이후 실제로 관리체계를 운영하고 정기적으로 점검하여 부족한 부분을 개선하는 방식으로 관리체계를 지속적으로 관리한다.

2. ISMS와 ISMS-P의 차이

2.1 ISMS

ISMS(Information Security Management System)는 조직의 정보와 정보시스템을 보호하기 위한 정보보호 관리체계 인증이다.

정보보호 정책, 위험관리, 접근통제, 인증 및 권한관리, 암호화, 시스템 운영 및 보안관리, 사고 대응, 재해복구 등 조직의 전반적인 정보보호 활동을 평가한다.

ISMS 인증기준은 다음과 같이 2개 영역으로 구성된다.

- 관리체계 수립 및 운영: 16개
- 보호대책 요구사항: 64개

따라서 총 80개의 인증기준으로 구성된다.

2.2 ISMS-P

ISMS-P는 ISMS의 정보보호 관리체계에 개인정보보호에 대한 요구사항을 추가한 인증이라고 볼 수 있다.

ISMS-P에서는 다음과 같이 3개 영역을 평가한다.

- 관리체계 수립 및 운영: 16개
- 보호대책 요구사항: 64개
- 개인정보 처리단계별 요구사항: 21개

따라서 총 101개의 인증기준으로 구성된다.

2.3 ISMS와 ISMS-P 비교

구분	ISMS	ISMS-P
정식 명칭	정보보호 관리체계 인증	정보보호 및 개인정보보호 관리체계 인증
핵심 목적	정보 및 정보시스템 보호	정보보호 + 개인정보보호

관리체계 수립 및 운영	16개	16개
보호대책 요구사항	64개	64개
개인정보 처리단계별 요구사항	없음	21개
항		
총 인증기준	80개	101개
주요 평가 대상	정보보호 관리체계	정보보호 및 개인정보보호 관리체계

2.4 ISMS와 ISMS-P의 핵심적인 차이

ISMS와 ISMS-P의 가장 큰 차이는 개인정보보호에 대한 요구사항이 포함되어 있는지 여부라고 생각할 수 있다.

간단하게 정리하면 다음과 같다.

ISMS = 정보보호 중심

ISMS-P = ISMS + 개인정보보호

ISMS는 조직의 정보와 정보시스템을 안전하게 보호하기 위한 관리체계를 중심으로 평가한다.

반면 ISMS-P는 여기에 개인정보보호에 대한 요구사항이 추가된다. 따라서 개인정보를 처리하는 조직에서는 개인정보를 수집하고 보유·이용하는 과정뿐만 아니라, 개인정보를 제공하거나 파기하는 과정까지 적절한 보호조치가 이루어지는지를 함께 관리해야 한다.

예를 들어 개인정보를 수집할 때에는 적절한 절차를 거치는지 확인하고, 개인정보를 보유하고 이용할 때에는 접근권한이나 안전한 관리가 이루어지는지를 확인해야 한다. 또한 개인정보를 더 이상 사용하지 않을 경우에는 안전하게 파기하는지도 중요하다.

결국 ISMS-P는 단순히 방화벽이나 백신, 암호화 같은 보안 솔루션을 사용하고 있는지만 확인하는 것이 아니라, 조직이 정보보호와 개인정보보호를 위한 관리체계를 만들고 실제 업무에 적용하여 지속적으로 점검하고 개선하고 있는지를 평가하는 인증이라고 이해할 수 있다.

3. 결론

ISMS와 ISMS-P의 가장 큰 차이는 개인정보보호 영역의 포함 여부이다.

ISMS는 정보보호 관리체계에 초점을 맞추며, 관리체계 수립 및 운영 16개와 보호대책 요구사항 64개를 합쳐 총 80개의 인증기준으로 구성된다.

ISMS-P는 ISMS의 기준에 개인정보 처리단계별 요구사항 21개가 추가되어 총 101개의 인증기준으로 구성된다.

따라서 간단하게 정리하면 ISMS는 조직의 정보보호 수준을 관리하기 위한 인증이고,

ISMS-P는 정보보호뿐만 아니라 개인정보보호까지 함께 관리하기 위한 인증이라고 이해하면 된다.